Lecture Notes S06: Kiến trúc Zero Trust & mTLS Gateway trong Hạ tầng Microservices

Học phần: Cơ sở hạ tầng khóa công khai (ATHK 512) · Lớp CHAT4P
Giảng viên: Nguyễn An Khương (Khoa Khoa học & Kỹ thuật Máy tính, Trường ĐHBK Tp. HCM · ORCID: 0000-0002-9910-6387)
Trợ giảng: Nguyễn Hữu Hoàng Huy

---

1. Cấu hình Envoy Gateway Làm Điểm Kiểm soát mTLS

Envoy Proxy là thành phần cốt lõi trong các hệ thống Service Mesh (Istio) và API Gateway Zero Trust: * Cấu hình `require_client_certificate = true` kích hoạt yêu cầu xác thực 2 chiều. * Sử dụng bộ lọc `envoy.filters.network.rbac` để đối chiếu giá trị SAN URI của chứng chỉ khách hàng: * Nếu SAN URI trùng khớp `spiffe://kma.edu.vn/ns/prod/sa/order-service`: Cho phép truy cập. * Nếu không trùng khớp hoặc chứng chỉ hết hạn: Từ chối với mã lỗi HTTP 403 Forbidden.

---

2. Chứng chỉ Sống Cực Ngắn (Ephemeral Certificates)

Trong môi trường Microservices và Container: * Các container có thể sinh ra và bị hủy trong vài phút. * Việc duy trì danh sách thu hồi CRL hoặc kiểm tra OCSP cho hàng triệu container gây quá tải mạng. * **Chiến lược Tối ưu:** Cấp phát chứng chỉ X.509 có thời hạn sống cực ngắn (Ultra-short-lived: 1 giờ đến 12 giờ) thông qua tiến trình SPIRE Agent chạy nền. Khi chứng chỉ hết hạn, tiến trình tự động xoay vòng khóa (Key rotation) mà không cần thu hồi.

---

3. Tài liệu Tham khảo Mở rộng

1. **NIST SP 800-207 (Zero Trust Architecture).**
2. **Matt Klein:** *Envoy Architecture and Networking Model*, CNCF.
3. **SPIFFE/SPIRE Documentation:** spiffe.io/docs